Pendientes de corregir — Sterclicks

Solo los puntos que no cumplen o cumplen parcialmente, ordenados de más a menos prioritario · 14 de agosto de 2026

Este documento resume únicamente las acciones pendientes del informe completo de auditoría. Los puntos marcados "No aplica" (funcionalidades que directamente no existen en el proyecto, como el sistema de consentimiento de marketing o el banner de cookies) no se incluyen aquí salvo que representen un riesgo real — ver el informe completo para el detalle de esos casos.

Prioridad 1 — Verificar en el servidor de producción (Hostinger)

Modo de entorno en producción sin confirmar RIESGO

`.env (local, en development) · app/Config/App.php:161 · app/Config/Logger.php:41`

El .env local tiene CI_ENVIRONMENT=development. Si el servidor real también estuviera así, se desactivarían forceGlobalSecureRequests (HTTPS forzado + HSTS) y se expondrían errores/debug detallados a los visitantes.

> **Arreglo:** entrar en el servidor de Hostinger y confirmar que el .env real tiene CI_ENVIRONMENT = production.

Posible exposición de archivos fuera de public/ CRÍTICO

`.htaccess (raíz, vacío) · env (archivo sin punto, trackeado en git) · baseURL apunta a .../public/`

El .htaccess de la raíz del proyecto está vacío. Como baseURL incluye "/public/", el DocumentRoot del hosting podría estar apuntando a la raíz del proyecto en lugar de a public/, dejando potencialmente accesibles por URL app/, vendor/, composer.json y el archivo "env" (plantilla, sin secretos reales, pero confuso).

> **Arreglo:** comprobar con Hostinger que el DocumentRoot apunta a public/. Si no es posible cambiarlo, añadir un .htaccess en la raíz que deniegue el acceso a todo excepto a public/. De paso, eliminar del repositorio el archivo "env" (sin punto) para evitar confusiones futuras con .env.

Cabecera HSTS sin confirmar en producción PARCIAL

`Filtro ForceHTTPS de CodeIgniter 4 (depende de forceGlobalSecureRequests)`

HSTS se activa automáticamente junto con forceGlobalSecureRequests, pero no se ha podido comprobar en vivo.

> **Arreglo:** una vez confirmado el modo producción, comprobar con "curl -I https://sterclicks.host" que llega la cabecera Strict-Transport-Security.

Cabecera de versión de PHP/servidor sin confirmar PARCIAL

`Configuración de Apache/php.ini (fuera del repositorio)`

No se controla desde el código de la aplicación.

> **Arreglo:** en Hostinger/php.ini, comprobar expose_php=Off y que Apache no envuelva la versión exacta en la cabecera Server.

Prioridad 2 — Continuidad de negocio

No existe ningún sistema de copias de seguridad NO EXISTE

`Sección F completa: BackupService, BackupController, BackupModel, RunBackup, aws/aws-sdk-php`

No hay ningún archivo, ruta, comando spark ni dependencia relacionada con backups en todo el repositorio. Es el hueco más grave de continuidad de negocio de toda la auditoría: si la base de datos se corrompe o se pierde, no hay forma de restaurarla desde la propia aplicación.

> **Arreglo:** a corto plazo, confirmar con Hostinger si el plan de hosting ya incluye backups automáticos de la base de datos como mitigación inmediata. A medio plazo, construir el sistema de backups descrito en el documento original (comando spark backup:run + cron + almacenamiento externo tipo B2/S3 + política de retención).

Prioridad 3 — Checkout e información al consumidor

Falta desglose de envío y plazo de entrega antes de pagar NO CUMPLE

`app/Views/frontend/checkout/payment_summary.php`

La pantalla de resumen del pedido solo muestra el total de artículos; no hay gastos de envío desglosados ni plazo de entrega estimado antes de que el cliente confirme.

> **Arreglo:** añadir una línea de envío (o una nota de "a confirmar" si el precio de envío se calcula después) y un plazo estimado de entrega, antes del botón "Confirmar pedido".

Falta aviso de exclusión del derecho de desistimiento NO CUMPLE

`app/Views/frontend/checkout/payment_summary.php · mencionado solo en terms.php sección 5`

El artículo 103.c del TRLGDCU exige un aviso explícito y visible de que los productos personalizados no tienen derecho de desistimiento, antes de confirmar el pedido — no basta con mencionarlo en las condiciones generales.

> **Arreglo:** añadir un texto visible tipo "Al tratarse de un producto personalizado, no aplica el derecho de desistimiento (art. 103.c TRLGDCU)" justo antes del botón de confirmar en payment_summary.php.

Falta enlace a la plataforma ODR de la UE NO CUMPLE

`No aparece en ninguna vista (footer, condiciones, contacto)`

Es obligatorio en comercio electrónico dirigido a consumidores de la UE incluir un enlace a la plataforma de resolución de litigios en línea.

> **Arreglo:** añadir el enlace a ec.europa.eu/consumers/odr en el footer o en la página de condiciones/contacto.

Prioridad 3 — Cabeceras de seguridad y XSS

Cabeceras de seguridad HTTP desactivadas NO CUMPLE

`app/Config/App.php:202 (CSPEnabled=false) · app/Config/Filters.php:86 (secureheaders comentado)`

Sin Content-Security-Policy, X-Content-Type-Options, X-Frame-Options ni Referrer-Policy, el sitio queda más expuesto a XSS y clickjacking.

> **Arreglo:** descomentar 'secureheaders' en globals[after] de Filters.php y activar CSPEnabled=true en App.php, ajustando la política para permitir los CDNs ya usados (jQuery, Bootstrap, Font Awesome).

Escapado de salida (esc()) no revisado de forma exhaustiva PARCIAL

`Vistas de app/Views/admin/*`

Se usa esc() en varias vistas, pero no hay una revisión sistemática de todos los campos de texto libre del cliente en las vistas del panel admin.

> **Arreglo:** auditar específicamente los campos de texto libre (nombre, comentarios de personalización, mensajes de contacto) allí donde se muestran en el admin, y envolverlos en esc() si no lo están.

Prioridad 3 — Autenticación

Sin 2FA en el panel de administración NO CUMPLE

`app/Config/Auth.php:102-105 ('login' => null)`

Shield ya trae soporte de Email2FA integrado, pero está desactivado.

> **Arreglo:** activar el Email2FA de Shield al menos para el grupo admin.

Prioridad 4 — RGPD y registro de usuarios

Registro sin enlaces legales ni checkbox de aceptación NO CUMPLE

`app/Views/frontend/register.php`

El formulario de registro no muestra ningún enlace a Términos/Privacidad ni pide aceptación explícita antes de crear la cuenta.

> **Arreglo:** añadir un checkbox obligatorio "He leído y acepto los Términos y la Política de Privacidad", con enlaces a ambas páginas.

Retención de datos de pedidos tras eliminar la cuenta, sin documentar PARCIAL

`app/Controllers/Frontend/ProfileController.php — deleteAccount()`

Al borrar la cuenta se anonimizan users/auth_identities y se borran direcciones, pero los pedidos conservan los datos personales tal cual (defendible por obligación contable/fiscal). Esto no está explicado en la política de privacidad actual.

> **Arreglo:** añadir un párrafo en privacy.php explicando que los datos de pedidos ya realizados se conservan por obligación legal/contable aunque se elimine la cuenta.

Prioridad 4 — Trazabilidad

Sin log de accesos al panel admin NO CUMPLE

`app/Filters/AdminFilter.php`

El filtro solo redirige si no hay sesión de admin válida; no registra quién entra, cuándo ni desde qué IP.

> **Arreglo:** añadir un log_message('info', ...) (o una tabla dedicada) en AdminFilter::before() con el id de usuario, la IP y la ruta accedida.

Logs sin rotación ni retención NO CUMPLE

`app/Config/Logger.php`

El FileHandler estándar de CodeIgniter 4 crea un archivo nuevo por día pero nunca purga los antiguos: crecen indefinidamente en writable/logs/.

> **Arreglo:** añadir una tarea programada (cron) que borre logs con más de X días, por ejemplo "find writable/logs -mtime +90 -delete", o un comando spark propio de limpieza.
